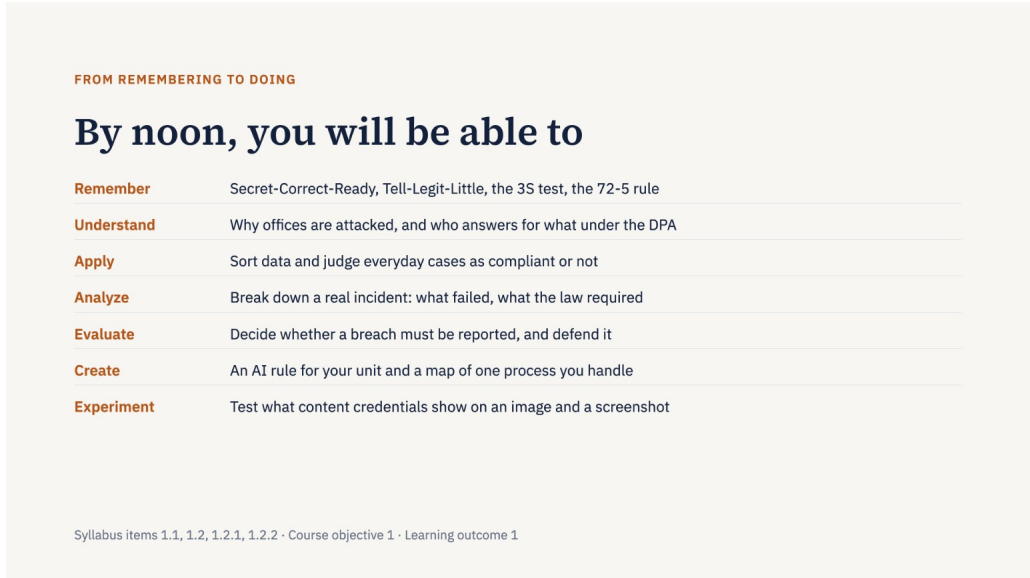


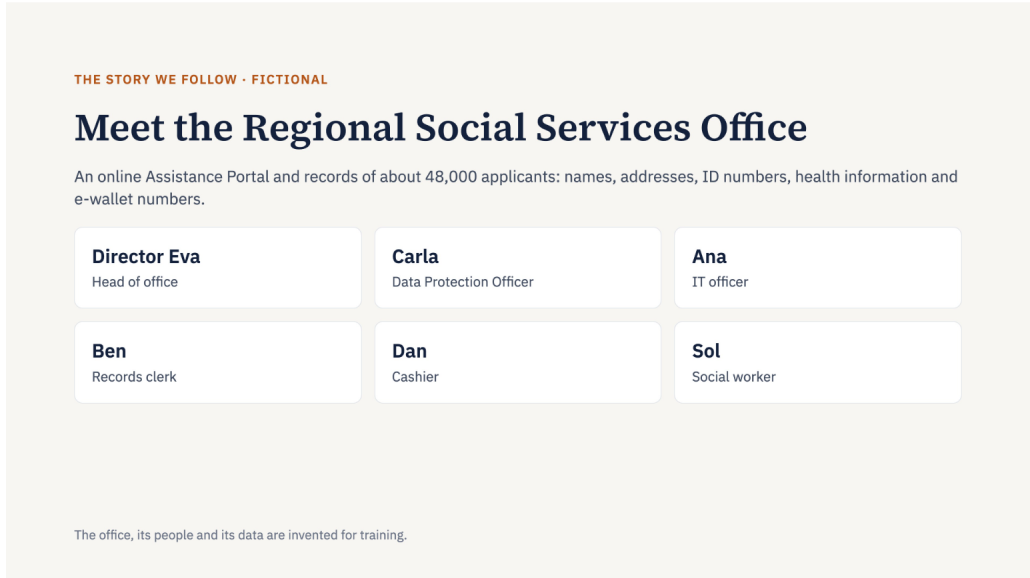
TIME: 2 minutes. SAY: Good morning. For three days we will talk about protecting the information citizens trust government with. This is not only an IT course. If you encode, file, approve, release or keep information about people, you are already protecting digital assets. ASK: Raise your hand if you handled a citizen's personal information in the last week. (Expected: almost everyone.) SAY: That is why everyone here belongs in this room. This morning we cover who attacks offices like ours, and the laws and standards that tell us what to do.



TIME: 5 minutes. SAY the ground rules: phones on silent; what is said here stays here (Chatham House rule); and please do not share real incidents, systems or names from your own office. We use fictional or already-public cases only. PRIVACY NOTICE: We collect only your name, office and email, for attendance and scoring. Scores are kept in one place with limited access and are released only as ILCDB directs. This is us practising what we teach. TEAMS: Form teams of 5 to 6 people from different offices, mixing technical and non-technical staff. These teams stay together for Module 2 and the Day 3 tabletop. Online: you are pre-assigned to breakout rooms.



TIME: 3 minutes. SAY: We will not stop at memorizing. Each level builds on the one before. Remembering lets you understand; understanding lets you apply; and by the end you will create something you can use in your own office on Monday. The four memory phrases on the first line are your anchors for the whole course; you will hear them again on Day 2 and Day 3. TIP: Point out the Check yourself questions in the learner guide. Trying to recall an answer before looking is what makes learning stick, so they should not peek.



TIME: 5 minutes. SAY: Every example today happens in one office, the RSSO. It is fictional, but it should feel familiar. Introduce each person and what they handle: Director Eva approves policies and public statements; Carla is the DPO and legal officer; Ana runs the portal, servers and backups; Ben encodes and files applications; Dan handles payouts and e-wallet lists; Sol does field visits and writes case notes. ASK: Which of these people are you most like? (Most participants will say Ben, Dan or Sol.) SAY: Good. By noon you will see that each of them can either open a door to an attacker or close it. The same office returns in Module 2 (threat model), Module 3 (controls), Module 4 (the lab) and Day 3 (the tabletop exercise).



TIME: 5 minutes. SAY: This is the most useful idea in the whole course. Every piece of information should stay Secret from the wrong people, Correct, and Ready when needed. Specialists call it the CIA triad; Secret, Correct, Ready is the same thing in plain words. Walk through the comparisons: a sealed envelope (anyone who opens it without permission breaks confidentiality); a stamped receipt (if someone alters the amount, integrity is broken); an office that opens on time (if citizens wait a week, availability is broken). ASK: Think of one record you handle. What happens if it leaks? If someone changes it? If it is gone for a week? Take two answers from non-IT participants first. WATCH FOR: People think security means only secrecy. Stress that a changed payout number or a portal that is down are security failures too, and often hurt citizens more.

1.1 MODERN CYBER THREATS

Who attacks, and what they want

Who	What they want	What they usually do
Criminal groups	Money	Ransomware, extortion, fake invoices
State-linked groups	Secrets, influence	Quiet, long intrusions to collect data
Hacktivists	Attention for a cause	Defacing or crashing websites, leaking data
Insiders	Gain, revenge, convenience	Misusing access; files on personal accounts
Vendors and partners	Nothing: they are the door	Their weak account becomes your way in

Most harm from insiders is accidental, not malicious.

TIME: 3 minutes. SAY: Explain the words as you go. Ransomware is software that locks your files and demands payment. Extortion is a threat to publish stolen data unless paid. A hacktivist attacks for a political or social cause, often by defacing a website (changing what it shows). An insider is anyone with legitimate access: staff, job-order and contract-of-service personnel, consultants. SAY: Two of the five are not outside attackers at all. An employee who forwards a list to a personal email to work faster is not a criminal, but the effect on the citizen can be the same. A vendor with weak passwords can become the door into our systems. ASK: Which of these five would most want what the RSSO holds? (Expected: criminals, because e-wallet numbers and ID numbers can be used for fraud.)



TIME: 3 minutes. SAY: These come from Microsoft's Digital Defense Report 2025, based on what Microsoft observed across its customers and services. They are not a census, but they show clear patterns. 52 percent: of attacks where the motive was known, more than half involved extortion or ransomware; only 4 percent were espionage. Most attackers want money, not state secrets. 20th: the Philippines ranked 20th among the most affected countries in the first half of 2025. 97 percent: almost all attacks on accounts go after passwords, and identity-based attacks rose 32 percent in the same period. 99 percent: multi-factor authentication, meaning a second proof such as a code on your phone, can block more than 99 percent of identity-based attacks, according to Microsoft. ASK: Who here has MFA on their office email? On their personal email? TAKEAWAY: Turning on MFA is the single cheapest, strongest step anyone can take today.

1.1 MODERN CYBER THREATS

Five doors attackers use

Door	What it looks like at your desk	What IT does
1. Phishing and stolen passwords	A message rushing you to verify, open or pay	Filtering, MFA, a report button
2. Old systems and lapsed licences	Warnings that updates or antivirus expired	Patch and renew on a schedule
3. Exposed websites	Public pages that show more than they should	Test, harden, monitor
4. Shared accounts	One unit password on a sticky note	One account per person, with logs
5. Personal apps for official files	Lists sent by personal email or chat	Approved tools that are easy to use

TIME: 5 minutes. SAY: Attackers rarely break in through clever technology. They walk through five ordinary doors. Phishing is a fake message that tricks you into clicking, opening a file or paying; by text message it is called smishing. Old systems and lapsed licences: an expired antivirus is an open door, as we will see in the 2023 case. Exposed websites: public pages or admin pages that show more than they should. Shared accounts: when five people use one password, no one can tell who did what. Personal apps: lists and scanned IDs in personal email or chat groups leave the office's control. ASK: Show of hands, no judgment: whose unit shares at least one account? Who has received official files through a personal chat group? SAY: The middle column is for everyone; the right column is for IT. Notice that every door has a desk side and a server-room side.

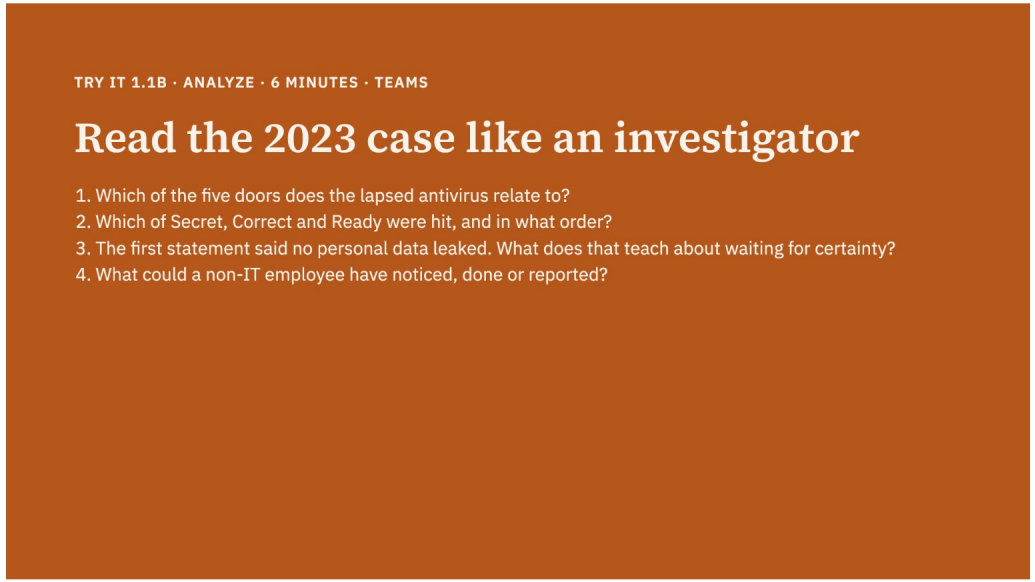
1.1 CASE STUDY · PUBLIC FACTS · AGENCY NOT NAMED

Ransomware at a national agency, 2023

When	What happened
A Friday, Sep 2023	Ransomware locked dozens of computers; the website and online services went down. The agency refused to pay a ransom.
3 days later	The agency notified the NPC, which asked it to explain, called a hearing and planned an onsite investigation.
4 days later	Its initial investigation said no personal information had leaked.
About 2 weeks later	Stolen files appeared online. The NPC found sensitive personal data in them.
17 days later	The agency confirmed its antivirus subscription had lapsed in April; procurement had delayed the renewal.

Sources: public news reports and an NPC statement (2023), held by the resource person

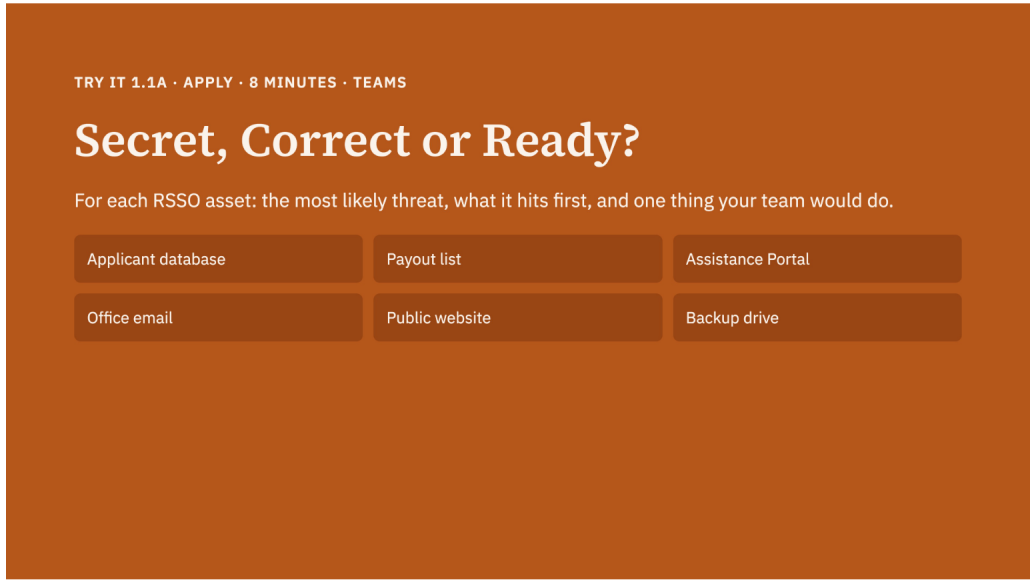
TIME: 4 minutes. SAY: This is a real, public case. We do not name the agency, because some of you may work in agencies like it, and our aim is lessons, not blame. Many offices could have been in the same position. Read the timeline slowly and point out three things. First, availability: the website and online services went down, and the public felt it. Second, the first assessment said no personal data had leaked; about two weeks later the NPC found sensitive personal data in what the attackers published. First assessments can be wrong. Third, a basic control had lapsed: the antivirus subscription expired in April, five months before the attack, and procurement had delayed the renewal. That is a planning problem, not only a technical one. NOTE: The agency advised the people affected to watch their accounts, change passwords and beware of phishing and smishing, because leaked data is often used for scams. The NPC also warned that downloading or sharing leaked data can itself be a crime. If a participant names the agency, acknowledge it calmly and keep to the public facts. FACILITATOR SOURCES: see the References section of the facilitation plan.



TIME: 6 minutes (4 in teams, 2 debrief). ANSWERS: 1. Door 2, old systems and lapsed licences. 2. Ready first (systems down), then Secret (stolen files published). 3. First assessments can be wrong, and the law requires notice on knowledge or reasonable belief, not certainty; you will see the 72-hour rule later. 4. Report expiry warnings and odd system behaviour; avoid suspicious links; in procurement and admin, plan security renewals before they expire; warn citizens about scams that use leaked data. FACILITATION: Ask a team with mostly non-IT members to answer question 4 first. Their answers show everyone has a role. Keep a list of good answers on the board; you will use it again in the recap.



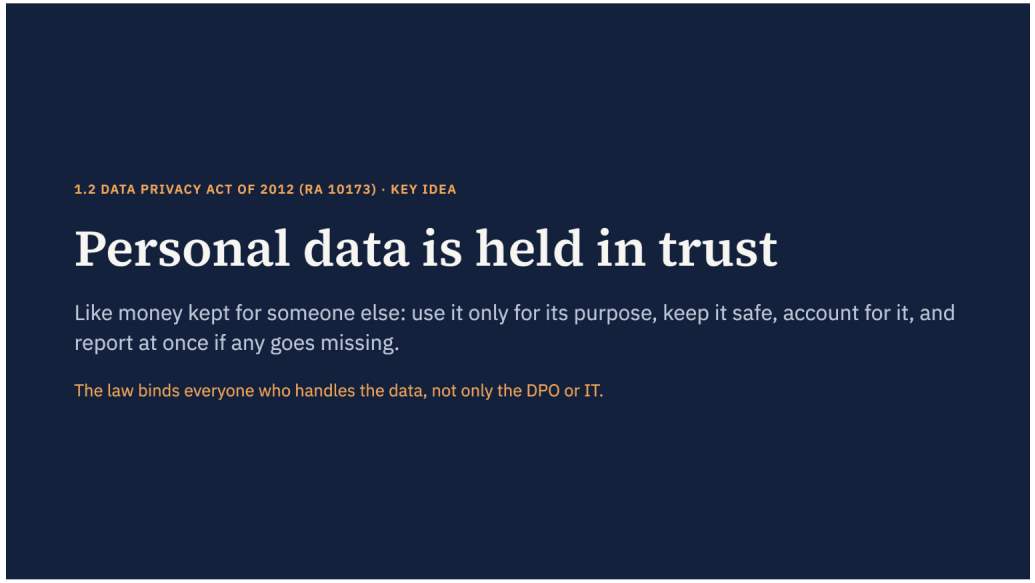
TIME: 4 minutes. SAY: This happened last month. We do not name the agencies. In early September, DICT confirmed unauthorized access to one national agency's website and an unauthorized change to another agency's web host; for the second, initial assessments found no sensitive databases or personal data compromised. A reported ransomware attack at a third agency was investigated, and DICT found no evidence of ransomware or a breach. Claims made online by attackers were not confirmed. SAY: On 8 September, DICT and the CICC put national agencies, GOCCs, LGUs and critical infrastructure operators on heightened cyber vigilance. Each had to give its head of office a one-page readiness assessment within 24 hours: the most serious risks, actions taken, help needed. Other priority measures: reduce unnecessary internet exposure, improve monitoring, and test incident response and continuity plans. ASK: Did your office prepare one? Who in your office would write it? (Many will not know. That is the point: they now know to ask.) LINK: This checklist returns in Bring it home at the end of the morning. FACILITATOR SOURCES: see the References section of the facilitation plan.



TIME: 8 minutes (5 in teams, 3 debrief on two assets). Face-to-face: teams fill the table in the learner guide. Online: one poll per asset. MODEL ANSWERS: Applicant database: data theft with stolen passwords, Secret first; MFA and need-to-know access. Payout list: e-wallet numbers changed by a fraudster or insider, Correct first; two-person approval and call-back before any change. Portal: ransomware or traffic floods, Ready first; tested backups and a continuity plan. Email: phishing, Secret first and then everything the account can reach; MFA and a report button. Website: defacement, Correct first; updates and a protected admin page. Backup drive: ransomware reaching the backups, or theft, Ready first and Secret if stolen; an offline copy, encryption and restore tests. DEBRIEF: Accept any answer with a sound reason. Ask a non-IT member to present.



TIME: 2 minutes. SAY: Before the break, here is what each of us does. If you handle data: pause when a message rushes you, and verify through a number you already know, never one in the message. Never share your password. Use only approved tools. Report anything odd at once, even if you are not sure; no one is punished for a false alarm. If you run systems: MFA starting with email, VPN and admin accounts; a calendar for patches and licence renewals (remember the 2023 case); test restores, not only backups; and make reporting easy and blame-free. TRANSITION: After the break we turn to the law that makes all of this an obligation: the Data Privacy Act.



TIME: 2 minutes. SAY: When a citizen gives us their information, it is like handing us money for safekeeping. We may use it only for what it was given for, we keep it safe, we account for it when asked, and if any of it goes missing we say so at once. That is the whole Data Privacy Act in one picture. SAY: The DPA binds the people who handle the data. Several DPA crimes, such as throwing records in the trash or giving access through negligence, can be committed by any employee, not only by the DPO or IT. WATCH FOR: Some participants believe privacy is the DPO's job alone. Correct this gently now; the penalties slide later makes it concrete.

1.2 DATA PRIVACY ACT

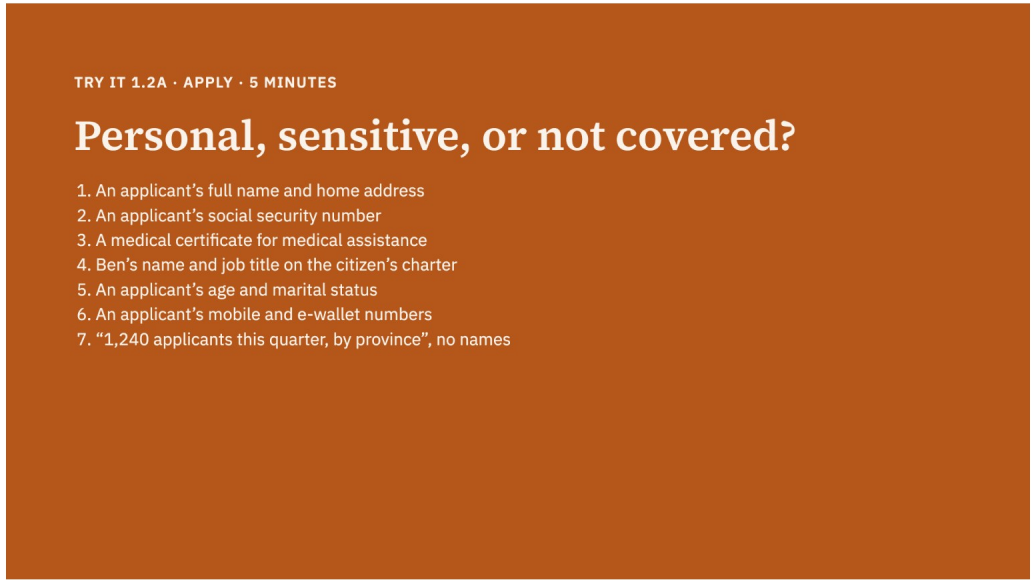
What counts as personal data

Type	Plain meaning	Examples
Personal information	Identifies a person, alone or with other details	Name with address; mobile number; photo
Sensitive personal information	Protected more strictly by law	Age, marital status, religion, ethnic origin, health, education, offenses, government ID numbers
Not covered	A government employee's job details	Name, title, office address and phone on a citizen's charter; a position's salary range

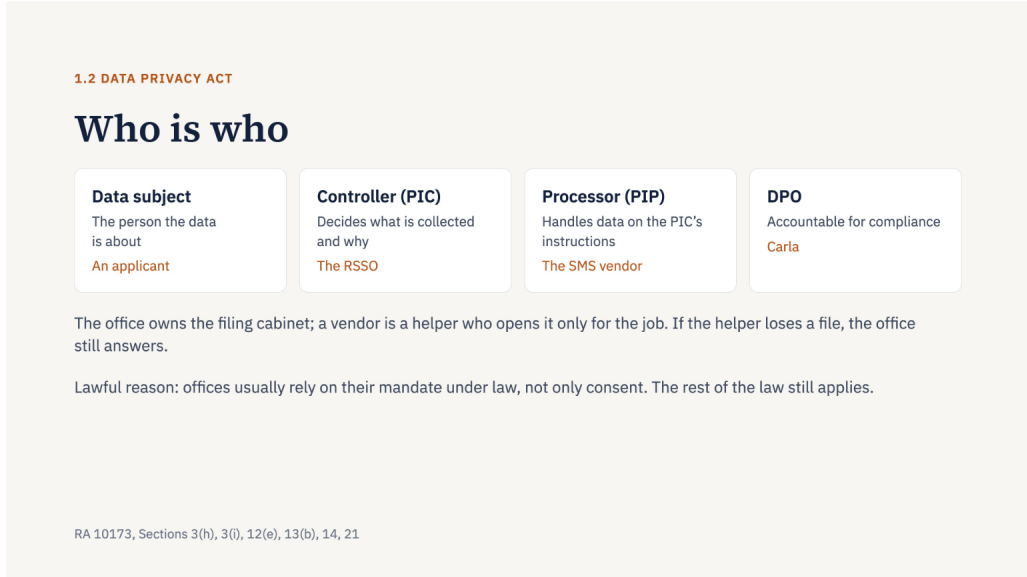
The RSSO may publish "Ben, Records Clerk". Not Ben's home address or health record.

RA 10173, Sections 3(g), 3(l) and 4(a)

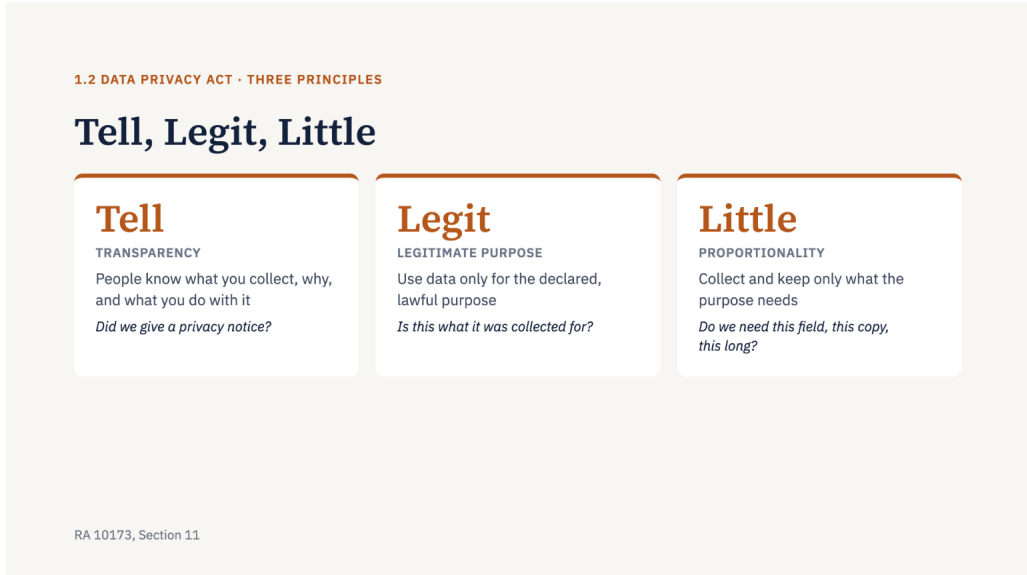
TIME: 4 minutes. SAY: Personal information is anything that identifies a person, on its own or when combined with other details. A mobile number alone may not name someone, but combined with a barangay and a birthday it does. Sensitive personal information is protected more strictly. The full list in Section 3(l): race, ethnic origin, marital status, age, color, religious, philosophical or political affiliations; health, education, genetic or sexual life; offenses and court proceedings; government-issued numbers such as social security numbers, health records, licenses and tax returns; and anything classified by law. SAY: Most government offices hold sensitive information every day, because government ID numbers are on the list. SAY: Section 4(a) says the DPA does not cover information about a government employee that relates to their position: the fact that they work there, their title, office address and phone, their position's classification and salary range, and their name on documents they prepared at work. That is why a citizen's charter can list staff names. ASK: Is a birthday personal or sensitive? (It reveals age, which is on the sensitive list.)



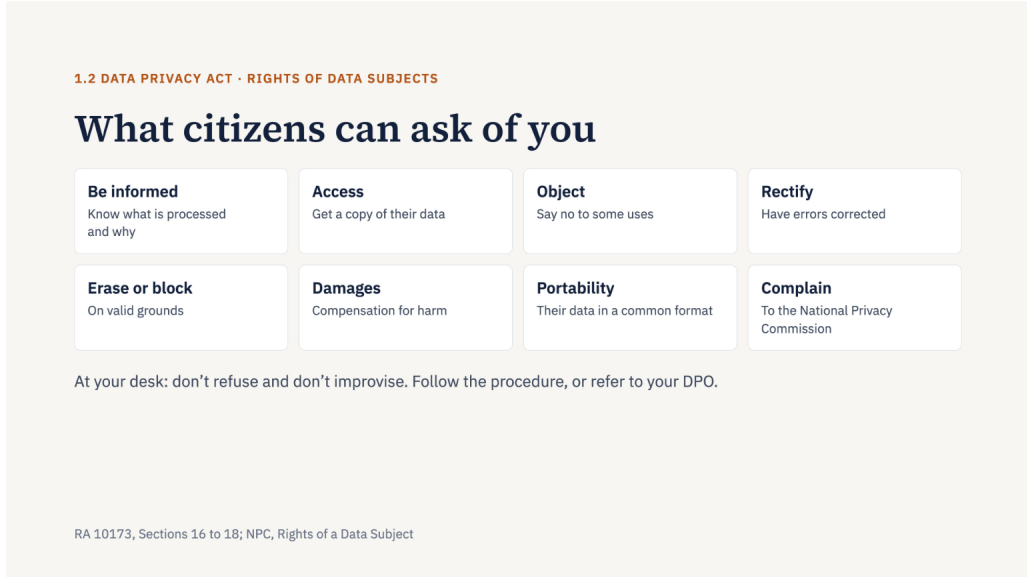
TIME: 5 minutes. Face-to-face: three cards per person, P, S and N, held up together for each item. Online: a quick poll. ANSWERS: 1. Personal. 2. Sensitive, a government-issued number. 3. Sensitive, health information. 4. Not covered, Section 4(a). 5. Sensitive, age and marital status. 6. Personal; not on the sensitive list, but an e-wallet number can be used for fraud, so it counts as high risk in the breach test later. 7. Not personal information if no one can be identified; but very small counts, such as one applicant from a small town, can point to a person. WATCH FOR: Item 6 usually splits the room. Use the split to preview the 3S test: the breach rules care about sensitive data and data that can enable identity fraud.



TIME: 4 minutes. SAY: Four roles. The data subject is the person the data is about. The personal information controller, or PIC, decides what is collected and why: here, the RSSO as an office. A personal information processor, or PIP, handles the data for the PIC and follows its instructions, like the SMS vendor or a contractor hired to encode forms. The DPO is the person accountable for the office's compliance. ANALOGY: The office owns the filing cabinet. A vendor is a trusted helper who may open it only for the job and only as instructed. If the helper loses a file, the office still answers to the citizen; Sections 14 and 21 keep the controller responsible and require contracts or other reasonable means to protect the data. LAWFUL REASON: A government office usually processes data because its mandate under law requires it (Section 12(e)), or, for sensitive information, because a law or regulation requires it (Section 13(b)). Consent is not always the basis. WATCH FOR: People think that having a mandate means privacy rules do not apply. They still do: the principles, security duties and people's rights.



TIME: 4 minutes. SAY: Section 11 has three principles. Remember them as Tell, Legit, Little. Tell: transparency, people know what we collect, why, and what we do with it; that is what a privacy notice on a form is for. Legit: legitimate purpose; use data only for the purpose we declared. Using the applicant list to invite people to a political event is not legitimate. Little: proportionality; collect and keep only what we need. If the form asks for religion and we never use it, remove the field. ASK: Think of one form your office uses. Is there a field you never use? (Collect two examples. This is the most practical change non-IT staff can propose on Monday.) WATCH FOR: Little also covers how long we keep data and how many copies exist: printouts, photocopies, files in personal folders.



TIME: 3 minutes. SAY: Citizens have eight rights. To be informed that their data is processed and why. To access a copy. To object to some uses, such as marketing or automated decisions. To have errors corrected. To have data erased or blocked on valid grounds. To be paid damages for harm caused by misuse. To get their electronic data in a common format. And to complain to the National Privacy Commission. Heirs can exercise these rights after a person dies. AT YOUR DESK: If an applicant asks to see or correct their record at the counter, do not refuse and do not improvise. Follow your office's procedure or refer to the DPO. ASK: Does your office have a procedure for these requests? Who handles them? (If many do not know, that is a Bring it home action.)



TIME: 4 minutes. SAY: Section 20 requires three kinds of measures. Organizational: rules, roles and routines, such as a privacy manual, a DPO, training and contracts with vendors. Physical: places and things, such as locked cabinets, a clean desk, shredding and a controlled server room. Technical: settings and software, such as passwords with MFA, encryption, backups, updates and logs. Notice that two of the three are not technical at all: non-IT staff carry out most of them. SAY: NPC Circular 2023-06 took effect on 30 March 2024 for both government and private offices, and replaced Circular 16-01. It requires privacy by design and by default (protection built into forms and systems from the start), regular training, access rules including the ability to remotely disconnect or wipe data on mobile devices, a business continuity plan with backup and restoration, and it bans sending personal data by fax. ASK: Which of the three does your unit do best? Which is weakest?

1.2 DATA PRIVACY ACT · FOR GOVERNMENT OFFICES

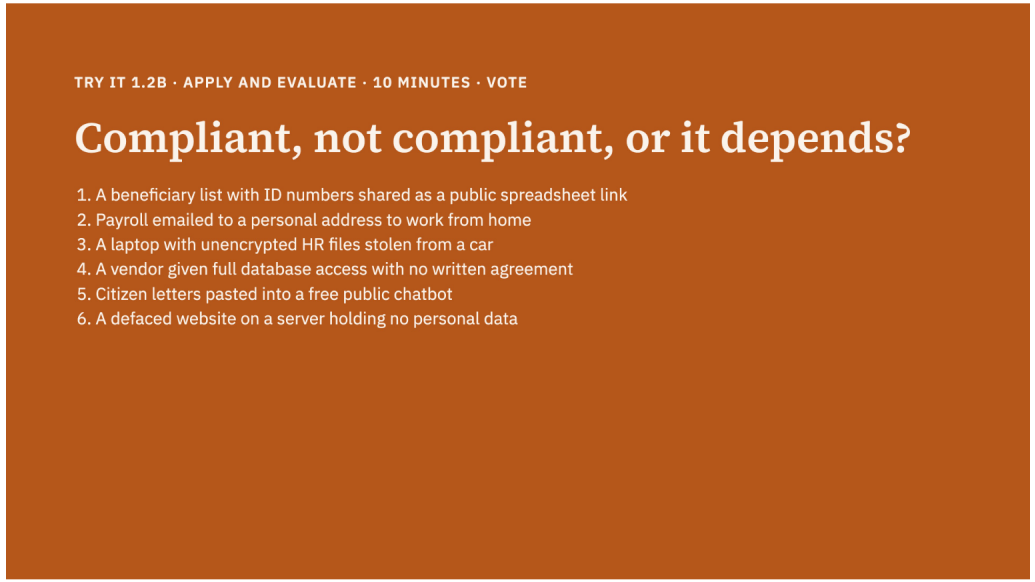
Extra rules for government

Rule	What the law says	Section
The head answers	Heads answer for securing the office's sensitive personal information	22
Clearance	No access to sensitive data without the agency head's security clearance	23
Off-site	Needs the head's approval within 2 business days; no answer means no	23
1,000 records	Approved off-site access covers no more than 1,000 records at a time	23
Encrypt	Devices and files used off-site must be encrypted	23
Contractors	1,000+ people's sensitive data: register with the NPC, same rules apply	24

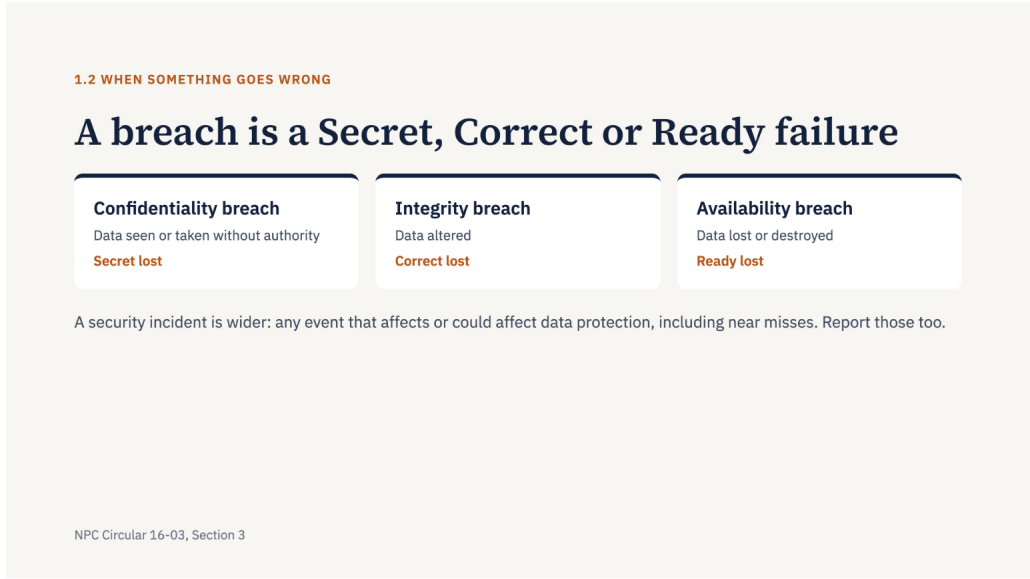
Ben wants to finish encoding at home on a USB stick. What does he need?

RA 10173, Sections 22 to 24

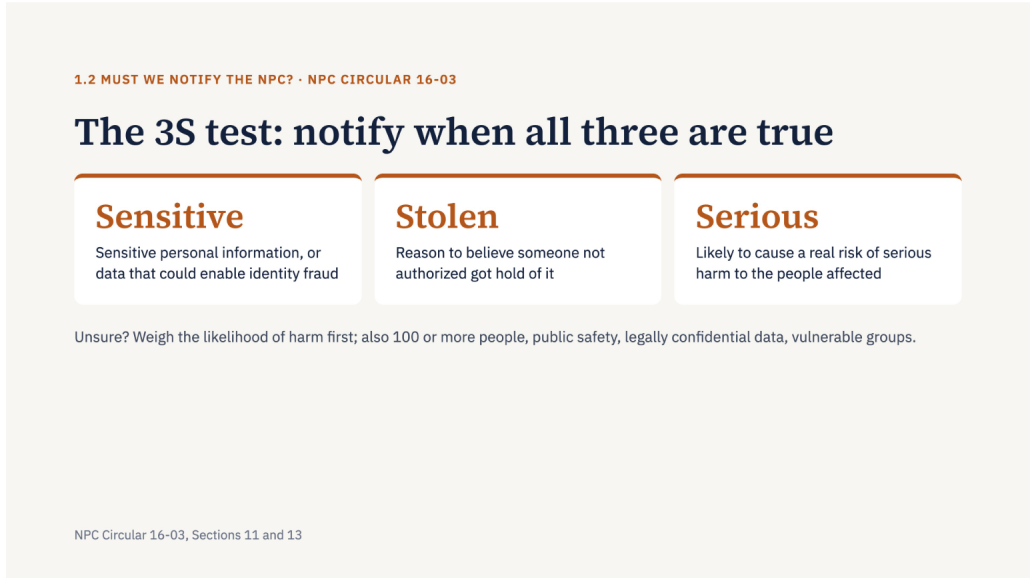
TIME: 5 minutes. SAY: These sections apply only to government, and few people know them. Section 22: heads of agencies answer for securing the sensitive personal information their office holds. Section 23: no employee may access sensitive personal information on government property or online without a security clearance from the head of the agency that holds it. Data may not be taken or accessed off-site without a request approved by the head, who must decide within two business days; no answer means no. Approved off-site access is limited to 1,000 records at a time, and anything used to store, carry or access it must be encrypted to the standard the NPC recognizes. Section 24: a contractor that handles sensitive personal information of 1,000 or more people for government must register its systems with the NPC and follow the same rules. ASK the question on the slide. ANSWER: written approval from the head, no more than 1,000 records at a time, and an encrypted USB stick. ASK: Has anyone ever taken work home this way? No names; just think about it.



TIME: 10 minutes. Vote on each (cards face-to-face, poll online), then ask one voter to give the reason before you reveal. ANSWERS: 1. Not compliant: anyone with the link can see ID numbers; if people with no right to it opened the link, it is likely a notifiable breach. 2. Not compliant: personal email is outside the office's control and access rules; payroll may include sensitive data such as tax and social security numbers. 3. Not compliant: data taken off-site must be encrypted (Section 23); sensitive HR data plus likely harm points to notification. 4. Not compliant: the office stays responsible for its vendors (Sections 14 and 21); the vendor needs a written agreement that sets its duties, and only the access its job needs. 5. Not compliant unless the tool is approved and personal data is removed first: pasting letters into a public tool discloses them to a third party. 6. It depends: no personal data, so not a personal data breach and no NPC notice; but it is a security incident: document it, fix it, check other systems, and report it under DICT's reporting mechanism. TIP: Item 6 is the bridge to the next slides.



TIME: 3 minutes. SAY: Here is where Lesson 1.1 and the law meet. NPC Circular 16-03 defines a personal data breach as a security failure that destroys, loses or alters personal data, or lets someone see or take it without authority. It names three kinds, and they are our three words. A confidentiality breach: data seen or taken. An integrity breach: data altered. An availability breach: data lost or destroyed. So in the 2023 case, the ransomware that locked the agency's systems was first an availability breach, and the publication of stolen files was a confidentiality breach. SAY: A security incident is wider: any event that affects or could affect data protection, including near misses that our safeguards stopped. Report near misses too; they show where the next breach will come from.



TIME: 4 minutes. SAY: Not every breach must be reported to the NPC. Circular 16-03, Section 11, requires notification when three things are true. Remember them as the 3S. Sensitive: the data is sensitive personal information, or any information that could be used to enable identity fraud. Stolen: there is reason to believe someone not authorized acquired it; seeing or copying it counts. Serious: the acquisition is likely to give rise to a real risk of serious harm to the people affected. SAY: When you are unsure, Section 13 says to put the likelihood of harm first, and to weigh whether the breach involves 100 or more people, national security or public safety, information that the law requires to be confidential, or vulnerable groups. ASK: The defaced website from the last activity, with no personal data on the server: does it pass the 3S? (No: Sensitive fails. But it is still documented and reported as a security incident.) WATCH FOR: Stolen does not need proof. Reason to believe is enough.



1.2 BREACH NOTIFICATION

72-5

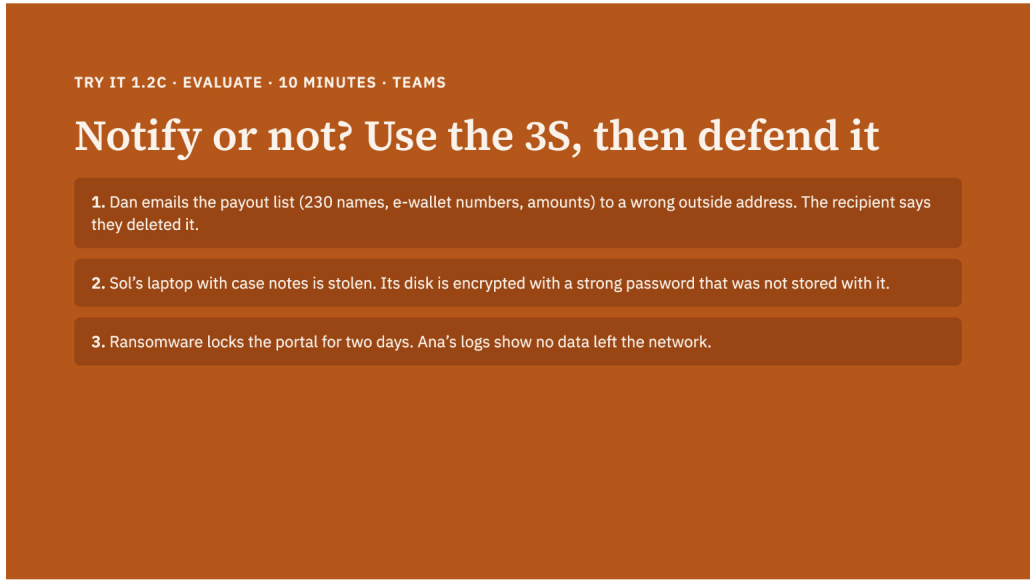
72 hours to notify. Full report in 5 days from discovery.

Smell smoke? Call. Don't wait for ashes.

Step	Rule
NPC	Within 72 hours of knowing or reasonably believing a breach happened
People affected	Within 72 hours, individually, by secure means; else ask the NPC for an exemption or postponement
No delay	100 or more people, or harmful sensitive data: notify within 72 hours on what you know
How	Online through the NPC's DBNMS; the full report to admindbnms@privacy.gov.ph
Records	Document every incident; an annual summary to the NPC
NPC silence	Is not approval; approvals are in writing

NPC Circular 16-03, Sections 17, 18 and 22; NPC Advisory 2026-02 (11 May 2026); DBNMS: dbnms.privacy.gov.ph

TIME: 5 minutes. SAY: Remember 72-5. The NPC must be notified within 72 hours of the office knowing or reasonably believing that a breach happened. Not certainty: reasonable belief. Think of a fire: you call when you smell smoke, not when you see ashes. The people affected must also be told within 72 hours, individually and through secure means; if that is not possible, the office must ask the NPC for an exemption or a postponement. Delay is allowed only to find the scope, stop further disclosure or restore systems, never to hide the breach. When 100 or more people are affected, or disclosure of sensitive information would harm them, there is no delay: notify within 72 hours using what you know. The full breach report follows within 5 days from discovery, even while any request to the NPC is pending (Advisory 2026-02). HOW: breach notifications and annual incident reports go only through the NPC's online Data Breach Notification Management System (DBNMS); the full breach report goes to admindbnms@privacy.gov.ph with the subject FBR_NameofPIC_NameofDPO. NPC silence is never approval. AT YOUR DESK: Your job is to report to your DPO or IT at once. The breach response team decides about the NPC. Concealing a breach is a crime in itself.



TIME: 10 minutes (6 in teams, 4 debrief). Each team gives a decision and one sentence of reasoning. MODEL ANSWERS: 1. Lean towards notifying. E-wallet numbers can enable fraud (Sensitive); an unauthorized person received the list (Stolen); 230 people are involved and the deletion cannot be checked (Serious, and 100 or more people means no delay). Notify the NPC within 72 hours, document the recipient's confirmation, and consider telling the people affected to watch their accounts. The breach response team and DPO make the final call. 2. Usually not notifiable. Strong encryption with the key kept separate makes the data unreadable, so serious harm is unlikely. Still record it as an incident, wipe the laptop remotely if possible, and write down the reasons for the decision. If the password was taped to the laptop, the answer changes. 3. Not notifiable on these facts: an availability breach with no sign that data left. Document it, keep investigating, and report the cybersecurity incident to DICT. Many ransomware groups copy data before locking it, as in the 2023 case; if new evidence shows data was taken, the 72-hour clock starts when you learn it. EMPHASIZE: Reasonable people can differ on case 1; what matters is a documented, defensible decision within the deadline.

1.2 WHY IT IS PERSONAL · SELECTED PENALTIES

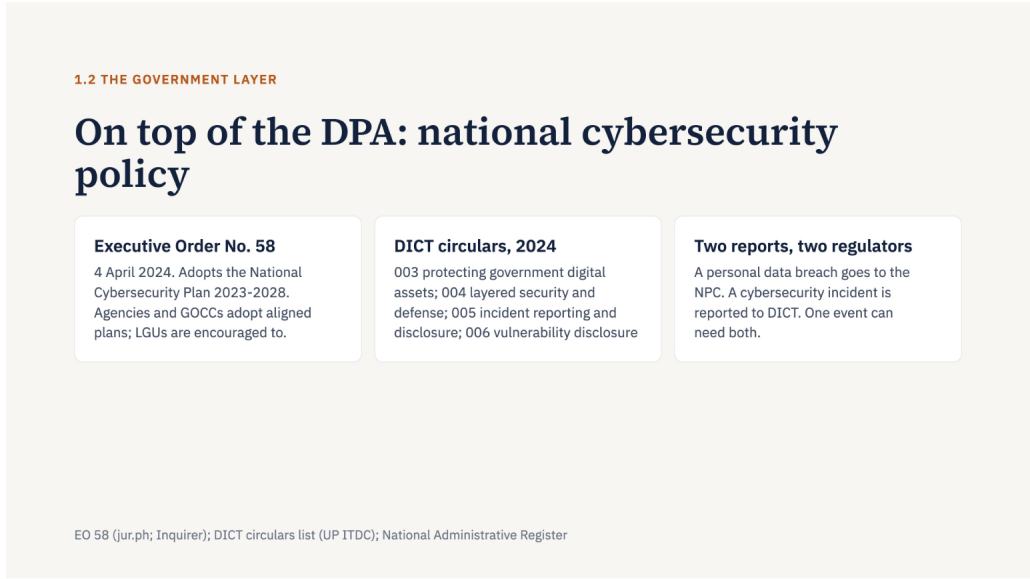
Everyday mistakes can be crimes

Act	How it happens	Personal info	Sensitive info	Sec.
Negligent access	Lending your password	1 to 3 yrs; P500k to P2M	3 to 6 yrs; P500k to P4M	26
Improper disposal	Printed lists in the trash	6 mos to 2 yrs; P100k to P500k	1 to 3 yrs; P100k to P1M	27
Unauthorized disclosure	A list sent to someone with no right to it	1 to 3 yrs; P500k to P1M	3 to 5 yrs; P500k to P2M	32
Concealing a breach	Keeping quiet about a reportable breach	1.5 to 5 yrs; P500k to P1M	Same	30

100 or more people affected: the maximum penalty applies (Sec. 35). Public officers: also disqualified from office for twice the prison term (Sec. 36).

RA 10173, Sections 26, 27, 30, 32, 35, 36 · Training material, not legal advice

TIME: 4 minutes. SAY: This slide is not meant to scare anyone. It shows that privacy is personal: these are acts any employee can commit. Negligence that gives someone access, for example lending your password or leaving the system open on a shared computer: 1 to 3 years and a fine of P500,000 to P2 million, or 3 to 6 years and up to P4 million if the information is sensitive. Throwing printed lists in the trash: 6 months to 2 years and P100,000 to P500,000, or 1 to 3 years and up to P1 million for sensitive information. Sending a list to someone with no right to it: 1 to 3 years, or 3 to 5 years for sensitive information. Concealing a breach that must be reported: 1 year and 6 months to 5 years and P500,000 to P1 million. When 100 or more people are affected, the maximum of the range applies. A public officer is also disqualified from public office for twice the prison term. The NPC can separately impose administrative fines of up to P5 million per act under Circular 2022-01. TAKEAWAY: The fix is cheap: never lend a password, shred, send only to people with a right to the data, and report at once. Remind them this is training material, not legal advice.



TIME: 3 minutes. SAY: On top of the DPA sits national cybersecurity policy. Executive Order No. 58, dated 4 April 2024, adopted the National Cybersecurity Plan 2023-2028. National agencies and GOCCs must adopt and implement aligned cybersecurity plans; LGUs are encouraged to. DICT then issued department circulars in 2024: No. 003 on cybersecurity protection of government digital assets, No. 004 on a layered security and defense approach, No. 005 on reporting and mandatory disclosure of cybersecurity incidents, and No. 006 on the Vulnerability Disclosure Initiative. Say only the titles: we will cover reporting in detail on Day 3. KEY POINT: two reports, two regulators. A personal data breach goes to the NPC under the DPA. A cybersecurity incident is reported to DICT under its reporting mechanism. The 2023 case needed both. ASK: Who in your office knows how to report to DICT? (Ask the ICT head; it is a Bring it home action.) RESOURCE PERSON NOTE: Before teaching any DICT reporting deadline, read the circular's full text; do not quote a number from memory.



TIME: 9 minutes. SAY: The DPA tells us what to protect and when to report. ISO/IEC 27001 tells us how to manage security so it does not depend on one careful person. It is the international standard for an information security management system, or ISMS: an organized way to decide which protections we need, put them in place, check that they work, and improve them. ANALOGY: You already know this cycle from the yearly planning and budget process: plan, implement, check results, adjust. ISO calls it plan-do-check-act. Clauses 4 to 10 are seven questions: 4, what do we protect and what affects us; 5, does top management lead; 6, what are our risks and which controls do we need; 7, do we have the people, skills and documents; 8, are we doing what we planned; 9, is it working; 10, what do we fix. The Statement of Applicability is the office's checklist of all Annex A controls: which apply, which do not, and why. RELATED: ISO/IEC 27002 explains how to apply each control. ISO/IEC 27701 covers privacy; its 2025 edition can be used on its own. WATCH FOR: Alignment is not certification. An office can follow the cycle without being certified.



TIME: 8 minutes. SAY: Annex A lists 93 controls in four themes. Remember them as Rules, People, Places, Tech. Rules, the organizational controls, 37 of them: policies, roles and routines, such as 5.9, keeping an inventory of information and assets; 5.15, access control; and 5.24 to 5.28, incident management, which ends with 5.28, collection of evidence. People, 8 controls: screening, training and behaviour, such as 6.3, awareness, education and training, and 6.7, remote working. Places, the physical controls, 14: rooms, locks and equipment, such as 7.9, security of assets off-premises (the laptop in the car). Tech, the technological controls, 34: systems and settings, such as 8.5, secure authentication; 8.13, information backup; and 8.24, use of cryptography. ASK: Which theme does a non-IT employee work in most? (All of them: Rules when following procedures, People when trained, Places when locking cabinets, and Tech when using MFA.) Do not read out all 93; participants meet these numbers again in Modules 3 to 5.

1.2.1 HOW THE PIECES FIT

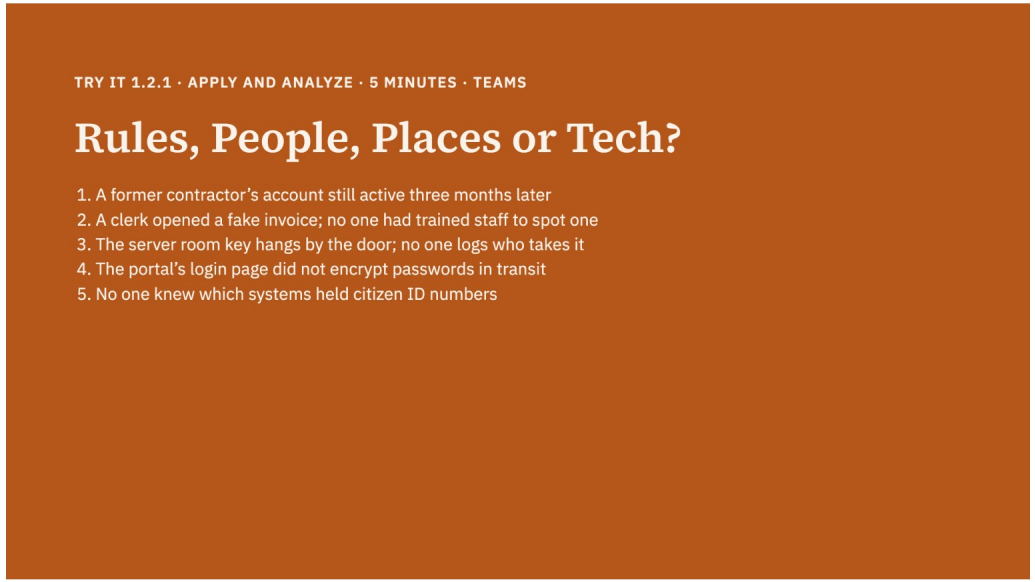
The DPA says what; ISO 27001 helps with how

The DPA and NPC ask for...	ISO 27001 helps you...
Organizational, physical and technical measures (Sec. 20)	Choose them by risk and record them in the Statement of Applicability
A breach response team, records and reports (Circ. 16-03)	Run incident management and evidence collection (5.24 to 5.28)
Regular staff training (Circ. 2023-06)	Run and measure awareness and training (6.3)
Backup, restoration and continuity (Circ. 2023-06)	Back up and test restores (8.13) within the continuity plan

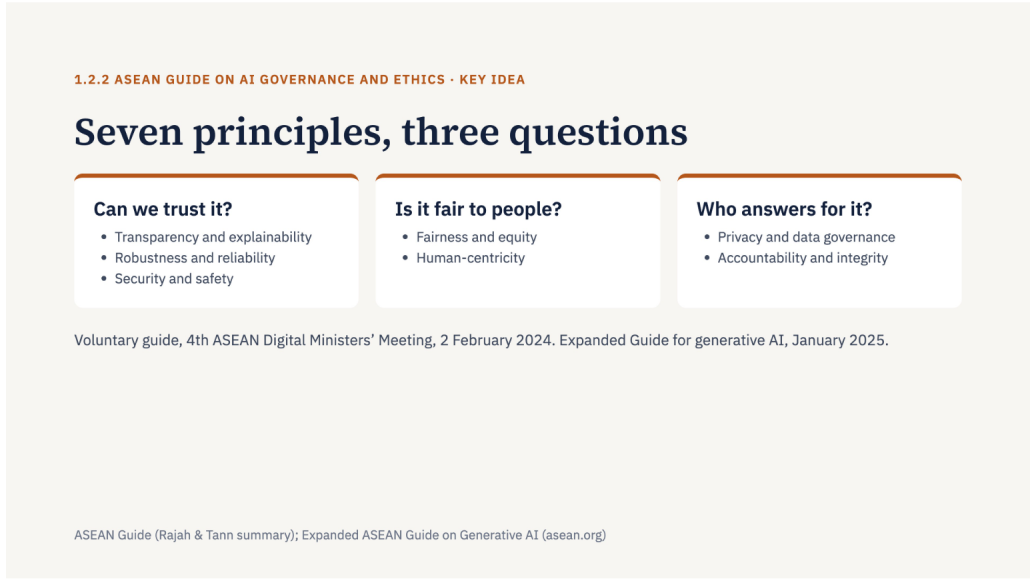
Start small: list your assets, find the top risks (Module 2), pick controls, name owners, check yearly.

RA 10173; NPC Circulars 16-03 and 2023-06; ISO/IEC 27001:2022

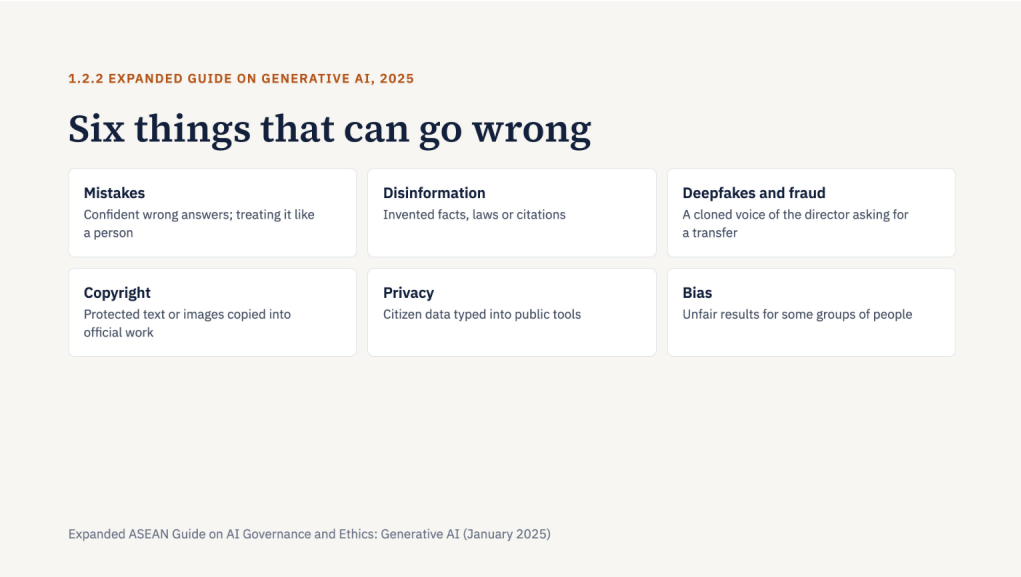
TIME: 6 minutes. SAY: The DPA and NPC circulars say what must be in place. ISO 27001 is a way to get there and to prove it. Walk across each row. Section 20 asks for organizational, physical and technical measures; ISO helps you choose them by risk and record them in the Statement of Applicability. Circular 16-03 asks for a breach response team, records and reports; ISO's incident controls, 5.24 to 5.28, cover the same ground. Circular 2023-06 asks for regular training and for backup, restoration and continuity; ISO controls 6.3 and 8.13 cover them. SAY: You do not need certification to benefit. Start small: list your information assets, find the top risks (that is this afternoon's Module 2), choose controls, give each one an owner, and check once a year. IT DEPTH: keep the Statement of Applicability as a living document and map each control to evidence (a policy, a log, a screenshot), so an NPC compliance check takes hours, not weeks.



TIME: 7 minutes (5 in teams, 2 debrief). ANSWERS: 1. Rules: access rights must end when the contract ends (the access control family, 5.15 to 5.18). 2. People: awareness, education and training (6.3). 3. Places: physical security of the server room. 4. Tech: use of cryptography (8.24). 5. Rules: inventory of information and other associated assets (5.9). DEBRIEF: Point out that only one of the five is purely technical. Most security failures are about rules, people and places, which is why everyone in the room has a part.



TIME: 4 minutes. KEY IDEA: Treat an AI tool like a new assistant: check its work, never hand it data it should not see, and keep a human responsible for every decision about a person. SAY: Many of us already use free AI chatbots to draft letters or summarize documents. The ASEAN Guide on AI Governance and Ethics, a voluntary guide unveiled at the 4th ASEAN Digital Ministers' Meeting on 2 February 2024, gives seven principles. Seven is hard to remember, so group them into three questions. Can we trust it: transparency and explainability, robustness and reliability, security and safety. Is it fair to people: fairness and equity, human-centricity. Who answers for it and its data: privacy and data governance, accountability and integrity. An Expanded Guide for generative AI followed in January 2025. ASK: Who has used an AI chatbot for work this month? (No judgment. Most hands go up. The next slides are about using it safely.)



TIME: 3 minutes. SAY: The Expanded Guide names six risks of generative AI, the kind of AI that writes text or makes images and audio. In its own words: mistakes and anthropomorphism (confident but wrong answers, and treating the tool as if it were a person); factually inaccurate responses and disinformation (invented facts, laws or citations; always check a citation before you use it); deepfakes, impersonation, fraudulent and malicious activities (a cloned voice of the director asking for an urgent transfer); infringement of intellectual property rights; privacy and confidentiality (citizen data typed into public tools); and propagation of embedded biases (unfair results for some groups). ASK: Which of the six is most likely in your office this year? (Usually privacy and invented facts.)

1.2.2 IN YOUR OFFICE · NPC ADVISORY 2024-04

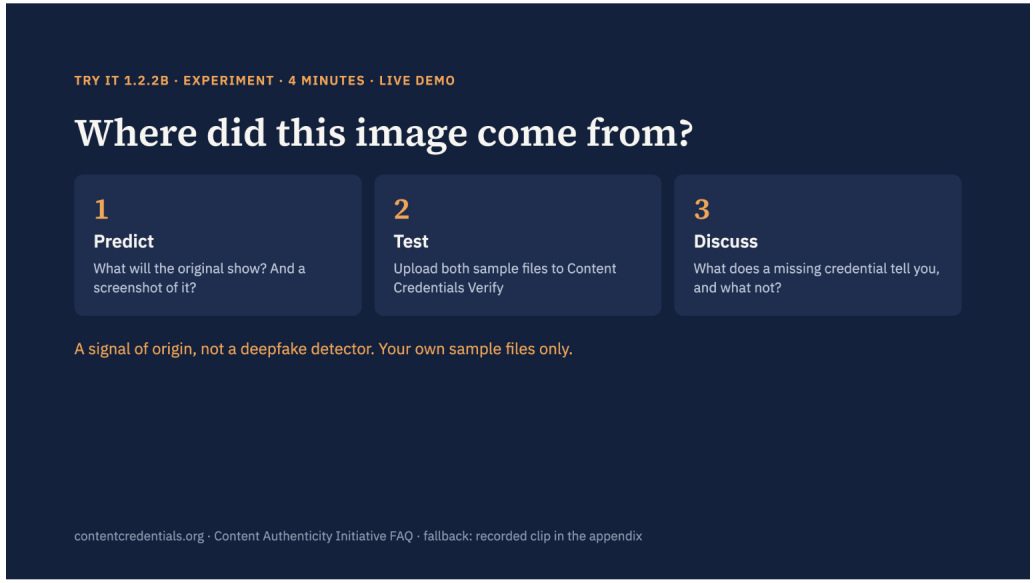
Your AI rules at work

Situation	Rule
Drafting a letter with a public chatbot	Remove names, ID numbers and case details, or use an approved tool
A tool ranks or screens applicants	A trained person reviews each decision; applicants can contest it
A vendor switches on AI features	Ask what data it uses and where it goes, before allowing it
An urgent call or video from “the director”	Verify through a number you already know

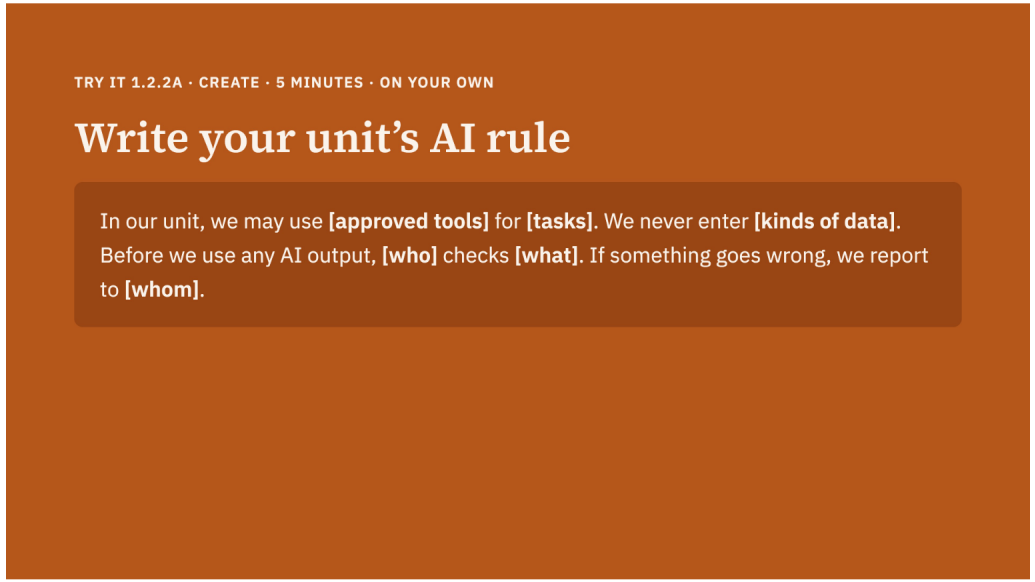
The DPA applies to AI: tell people, stay accountable for vendors, use only needed data, keep human review of risky decisions.

NPC Advisory 2024-04 (19 December 2024), on AI systems processing personal data

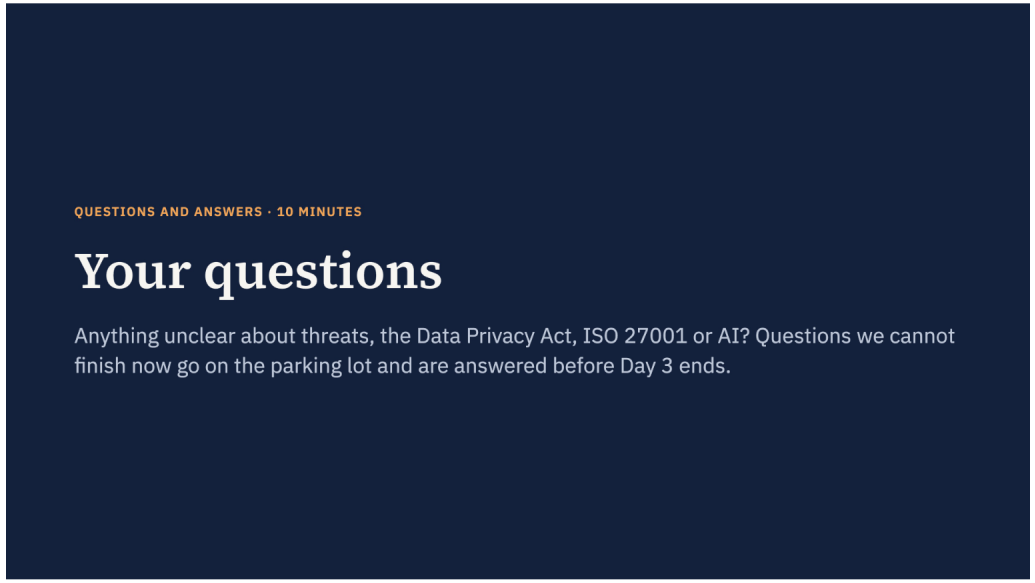
TIME: 4 minutes. SAY: In the Philippines, NPC Advisory 2024-04, dated 19 December 2024, applies the Data Privacy Act to AI systems that process personal data. In plain words: tell people how AI is used on their data; the office stays accountable even when a vendor runs the AI; where automated decisions carry significant risk, a competent person must review them and people must be able to question and contest them; watch for and reduce bias; keep data accurate; use only the personal data the AI actually needs; have a lawful basis first, and remember that publicly available data is still protected; and let people exercise their rights. Walk through the four rules on the slide. ASK: Case: the screening tool rejects an applicant and no one can explain why. Which ASEAN principle is at stake? (Transparency and explainability; under the NPC advisory, the applicant must also be able to contest it.)



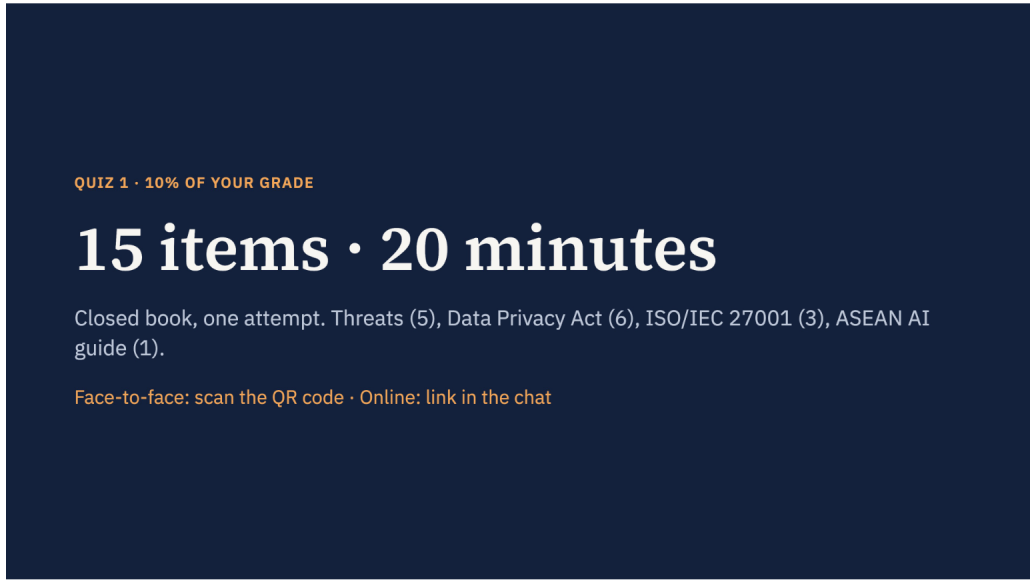
TIME: 4 minutes. PREPARE: two files of your own: an image that carries Content Credentials (for example one exported from a tool that adds them) and a screenshot of the same image. Test both on the venue network the day before. SAY: Content Credentials are signed information attached to a file that shows how it was made and edited, and tampering with them leaves a trace. They follow an open standard called C2PA, which the Expanded ASEAN Guide points to for content provenance. PREDICT: Ask the room what each file will show. TEST: Upload both. The original shows its history; the screenshot shows no content credential. DISCUSS: A missing credential does not prove a file is fake; it only means the origin is unknown, because screenshots and many re-saved files do not carry credentials. Credentials can show AI generation only if the AI tool adds them. They are a signal of origin, not a deepfake detector. RULE: Never upload office or citizen files to a public site. If the site does not load, play the 60-second clip.



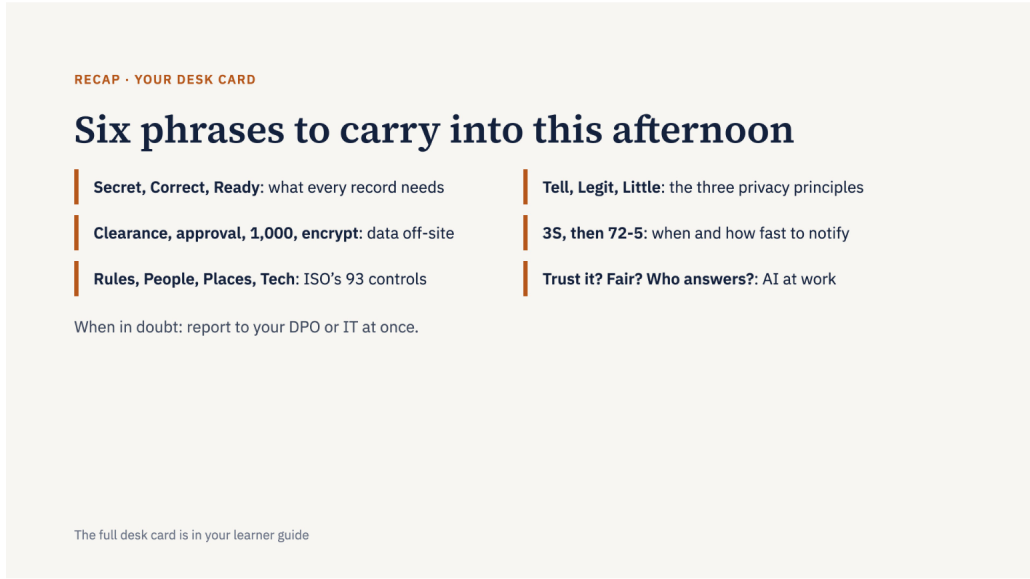
TIME: 5 minutes (3 writing, 2 sharing). SAY: Fill in the sentence for your own unit; it is also in your learner guide. Then read yours to the person beside you. Invite two volunteers to read theirs aloud, ideally one from a non-IT unit. GOOD EXAMPLE: In our unit, we may use the office-approved assistant for drafting and summarizing public documents. We never enter names, ID numbers, health information or case details. Before we use any AI output, the drafter checks every fact and citation against the source. If something goes wrong, we report to our DPO. WHY THIS MATTERS: This is the Create level. A rule they wrote themselves is far more likely to be used on Monday than one they were told.



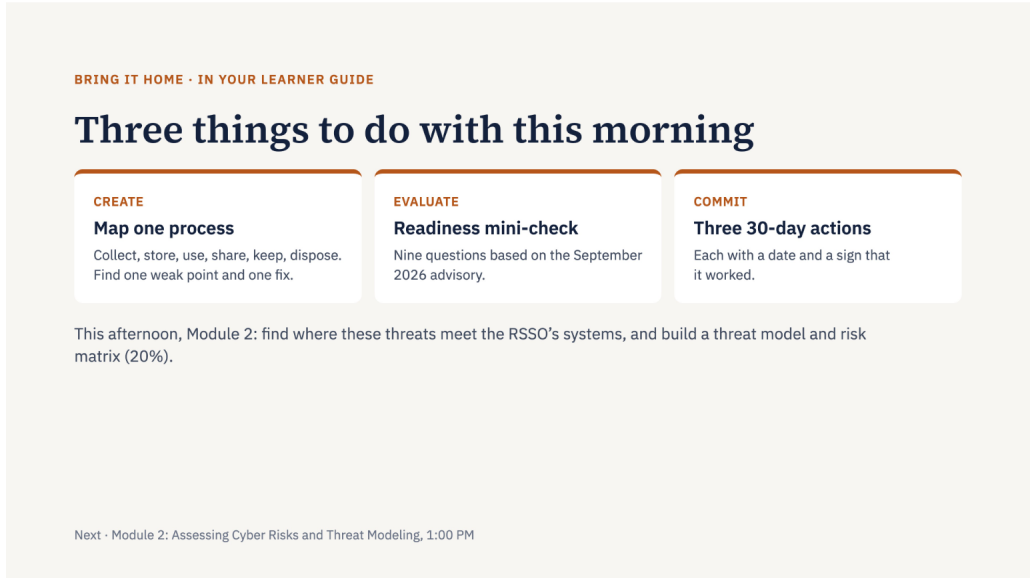
TIME: 10 minutes. Start with the parking-lot questions collected so far. Online, the co-host reads questions from the chat. COMMON QUESTIONS AND SHORT ANSWERS: (1) Does the DPA apply to paper records? Yes. It covers personal information whether or not it is recorded in electronic form, and Circular 2023-06 has rules for paper filing systems. (2) We have a mandate; do we still need a privacy notice? Yes. Transparency still applies even when consent is not the basis. (3) Who decides whether to notify the NPC? The office's breach response team, which must include at least one person who can make immediate decisions; the DPO may be a member. (4) Is our office certified to ISO 27001? Most are not, and certification is not required by the DPA; following the cycle still helps. (5) Can we use ChatGPT or similar tools? Follow your office's approved-tools policy; never enter personal data into public tools. If a question needs a legal opinion, say so and refer it to the DPO or the NPC. Do not guess.



TIME: 25 minutes (20 for the quiz, 5 for the answer review). BEFORE THE SESSION: add the QR code and short link for this run's quiz form to this slide; keep printed copies and answer sheets as backup. DURING: start the countdown on the main screen; walk the room face-to-face; online, keep cameras on where bandwidth allows. AFTER: review the two or three items most people missed, using the desk card phrases (Secret-Correct-Ready, Tell-Legit-Little, 3S, 72-5, Rules-People-Places-Tech). Scenario items test reasoning, for example whether a described incident meets the three notification conditions.



TIME: 5 minutes. RETRIEVAL FIRST: before you reveal the slide (black screen with B), ask the room to call out the memory phrases from this morning. Then reveal and check. This recall is what fixes them in memory. SAY each one with its action: Secret, Correct, Ready: ask what happens if a record leaks, changes or is gone for a week. Tell, Legit, Little: tell people, use data only for its purpose, collect and keep only what is needed. Clearance, approval, 1,000, encrypt: the government rules for taking data off-site. 3S, then 72-5: Sensitive, Stolen, Serious; then 72 hours to notify and 5 days for the full report. Rules, People, Places, Tech: ISO's four themes, 93 controls. Trust it, Fair, Who answers: the three AI questions. And when in doubt, report to your DPO or IT at once. TIP: Open Module 2 this afternoon with three of these as a quick quiz; recalling them again after a break makes them stick.



TIME: 5 minutes. SAY: Learning sticks when you use it within days. Your learner guide has three Bring it home tasks. Map one process you handle, from collecting the data to disposing of it, and find one weak point and one fix; your map feeds this afternoon's risk assessment. Do the readiness mini-check, nine questions based on the September 2026 DICT and CICC advisory; each unticked box is a candidate action. Write three 30-day commitments, each with a date and a sign that it worked; we come back to them at the course close on Day 3. PREVIEW: This afternoon we take the RSSO and find where these threats meet its systems, then build a threat model and a risk matrix as a team; that activity is worth 20 percent. Thank everyone and announce the lunch break.